

Stoquify 70+ Skills Installation Feasibility Plan

Seven qualified skills under a governed Phase A approval gate

INSTALLATION FEASIBILITY PLAN

Prepared 2026-08-05

Evidence-led | read-only assessment | governance-first

Pinned sources. Explicit controls. Reproducible evidence.

Date: 2026-08-05 **Phase:** A — planning and evidence only

Status: Complete for human review; **no candidate approved, installed, downloaded, executed, configured, or activated**

1. Executive decision

Seven candidates scored at least 70 in today's two expert reports. Their scores and original verdicts are preserved below. A score at or above 70 is an eligibility threshold, not approval.

Supabase supabase-postgres-best-practices	93.5	Adopt now, governed and pinned	Eligible for a separate Phase B project-local, report-only Codex skill install
Addy Osmani web-quality-audit	83.5	Adopt now as a governed checklist, not as certification	Eligible for a separate Phase B project-local guidance install after script/content allowlisting
Impeccable	83.0	Adopt capability via controlled read-only pilot	Do not install the agent bundle first; evaluate the pinned detector CLI in a disposable, hook-free pilot
Alibaba Open Code Review	82.5	Controlled pilot; data-governance override blocks direct adoption	Blocked from Stoquify source; later synthetic-only tool-and-skill pilot needs egress and binary approvals
Sentry sentry-nextjs-sdk	78.5	Controlled, privacy-hardened pilot only	Blocked; the scored skill is superseded and the current Codex plugin auto-configures a hosted MCP endpoint
Trail of Bits supply-chain-risk-auditor	74.5	Controlled advisory pilot	Do not install upstream unchanged; adapt a read-only Stoquify advisory pattern after legal review
Anthropic Skill Creator	70.5	Selectively adapt methods; no whole-skill install	No install; reuse evaluation patterns inside the existing Codex skill lifecycle

Recommended sequence after separate approvals:

- 1
- Install the pinned Supabase and Addy guidance skills project-locally, validate each with the current Codex validator, and keep both report-only.
- 2
- Run Impeccable's pinned deterministic detector in a disposable location without hooks, `init`, `PRODUCT.md`, `DESIGN.md`, or agent writes.
- 3
- Adapt the useful Anthropic evaluation methods into the existing Codex lifecycle; do not install a duplicate `skill-creator`.
- 4
- Consider a synthetic-only Alibaba pilot after provider, egress, retention, telemetry, and binary-provenance approval.
- 5
- Adapt the Trail of Bits heuristics into Stoquify's existing release-evidence model; keep the result advisory.
- 6
- Keep Sentry disabled until a privacy-approved telemetry contract and a safe, explicitly pinned distribution plan exist.

2. Hard stop and non-actions

This run performed read-only local discovery and primary-source research, then created this plan, its PDF rendering, and the companion JSON manifest. It did **not**:

- 1
- install or download a candidate;
- 1
- run `npm`, an upstream installer, a package post-install script, a downloaded binary, or an upstream hook;

- 1 modify product code, dependencies, database schemas, CI, hooks, runtime configuration, or environment variables;
- 1 inspect or write `.env` values;
- 1 connect Sentry, Supabase, GitHub, a model provider, or any other external service;
- 1 transmit Stoquify source, diffs, customer data, payroll data, financial data, authentication data, provider data, audit data, or production data;
- 1 enable auto-fix, autonomous writes, CI blocking, or privileged tools;
- 1 run application checks, because Phase A changed no application code or dependencies.

The worktree was already dirty. All unrelated user changes were preserved.

3. Evidence and local inventory

3.1 Evaluation sources

Scores and original verdicts were taken from:

- 1 docs/agents-and-skills/STOQUIFY_NEXT_5_ESSENTIAL_SKILLS_EXPERT_REPORT_2026-08-05.md
- 1 docs/agents-and-skills/STOQUIFY_EXTERNAL_SKILLS_EXPERT_REPORT_2026-08-05.md

No candidate below 70 was added.

3.2 Current local state

Read-only inventory found:

- 1 no installed copy of the six uniquely named external candidates in the global Codex/agent roots or project-local skill roots;
- 1 an existing Codex system skill at `C:\Users\J COMPUTER\.codex\skills\.system\skill-creator`, which conflicts functionally and by name with installing Anthropic Skill Creator;
- 1 no `ocr`, `impeccable`, or `sentry-cli` command on PATH;
- 1 GitHub CLI `gh` present, but authentication and account scopes were not inspected;
- 1 no `@sentry/nextjs` or Supabase package in `package.json` dependencies or dev dependencies;
- 1 the approved application-check scripts exist: `typecheck`, `lint`, `policy: gates`, `prisma: validate`, and `test: e2e`.

3.3 Codex installation and validation authority

The current local Codex installer supports a GitHub repository/path with an exact `--ref`, an explicit destination, and download or sparse-checkout methods. Its networked installer was inspected but not run. A proposed Phase B must use:

- 1 installer: `C:\Users\J COMPUTER\.codex\skills\.system\skill-installer\scripts\install-skill-from-github.py`
- 1 validator: `C:\Users\J COMPUTER\.codex\skills\.system\skill-creator\scripts\quick_validate.py`
- 1 project-local destination: `E:\ohada saas\Focused projects\stoquify\.codex\skills`

Every Codex skill installed in an approved Phase B must pass that validator **before first use**. Successful schema validation is necessary but not security, privacy, accessibility, accounting, statutory, or release certification.

4. Installable-unit classification

Supabase	Instruction/reference directory	Yes	Supabase SaaS, CLI, SDK, database policy, and migrations are separate and out of scope
Addy	Instruction/reference directory with possible script surface	Yes	Lighthouse/browser tooling and standards evidence remain separate
Impeccable	Agent skill bundle plus npm CLI, detector, hooks, live browser mode, and document-writing workflows	Partly	Detector CLI is the proposed pilot; skill, hooks, subagent, browser mode, and writes are not approved
Alibaba	Portable skill that invokes the separate ocr CLI	Yes, but non-functional alone	CLI binary, model provider, credentials, telemetry, session store, CI, MCP, and auto-fix are separate approvals
Sentry	Scored legacy skill; current successor is a generated Codex plugin plus hosted MCP and runtime SDK guidance	Legacy only	Plugin, MCP, SaaS account, DSN/token, @sentry/nextjs, source maps, replay, AI/Seer, and production activation are separate
Trail of Bits	Instruction skill with Read, Write, Bash, Glob, Grep declarations and gh use	Format-compatible, not safe as-is	GitHub access, report writes, deterministic SCA/SBOM/license/CVE tools, and release gating are separate
Anthropic	Claude-oriented skill-authoring/evaluation workflow	Portable concepts only	Claude runtime/API/helpers and Codex skill governance are separate; existing Codex skill-creator remains authoritative

5. Candidate plans

5.1 Supabase supabase-postgres-best-practices — 93.5

Preserved verdict: Adopt now, governed and pinned. Use first as a report-only reviewer; do not auto-apply SQL or migrations.

Stoquify value. High-value guidance for tenant isolation, PostgreSQL constraints, indexing, query plans, concurrency, locking, connection management, and RLS review. Supabase-specific identity examples such as `auth.uid()` must be translated into Stoquify's Better Auth/Prisma/Neon organization vocabulary and never copied literally.

Source and pin. `supabase/agent-skills`, path `skills/supabase-postgres-best-practices`, commit `1ad9aaeb49caafd9e95c0a91116f71890eebbc53`. The repository declares MIT. The selected directory contains `SKILL.md`, references, and a changelog; it is guidance rather than a runtime SDK.

Proposed Phase B command — documented, not executed:

```
`powershell & 'C:\Users\J
COMPUTER\.cache\codex-runtimes\codex-primary-runtime\dependencies\python\python.exe'
'C:\Users\J
COMPUTER\.codex\skills\.system\skill-installer\scripts\install-skill-from-github.py'
--repo supabase/agent-skills --path skills/supabase-postgres-best-practices --ref
1ad9aaeb49caafd9e95c0a91116f71890eebbc53 --dest 'E:\ohada saas\Focused
projects\stoquify\.codex\skills' ``
```

Preflight. Security/DB owner reviews every file at the pin; records MIT license/notice, file inventory, locally computed SHA-256 values, and upstream tree/commit; confirms no scripts, hooks, MCP, credentials, network calls, package

changes, or hidden writes; checks for an existing skill name collision.

Validation before use. Run the current Codex validator against `.codex\skills\supabase-postgres-best-practices`; then use only on synthetic or repository documentation/SQL review with report-only output. A principal database/security reviewer must verify any recommendation against Prisma pooling, migrations, negative cross-tenant tests, query plans, and concurrency tests.

Rollback. Confirm the resolved target is exactly the project-local candidate directory, delete only that directory, restart/reload Codex, verify it no longer appears, and confirm `git status --short` contains no unexpected residue. This removal must be tested in the pilot before promotion.

Approval owners. Database architecture, security, agent governance, legal/procurement for MIT notice handling.

5.2 Addy Osmani web-quality-audit — 83.5

Preserved verdict: Adopt now as a governed checklist, not as certification.

Stoquify value. A unified evidence checklist across performance, Core Web Vitals, accessibility, SEO/public surfaces, and browser best practices. It can standardize evidence for EN/FR golden journeys, but it cannot certify WCAG conformance, production performance, security, or release readiness.

Source and pin. `addyosmani/web-quality-skills`, path `skills/web-quality-audit`, commit `7b59d48aaf1f793935002f4998dfccc656f40839`. The repository is explicitly unofficial and declares MIT. The candidate must be inspected for referenced scripts, especially shell-oriented analysis helpers; guidance may be installed only after an allowlist confirms what the agent can read or invoke.

Proposed Phase B command — documented, not executed:

```
`powershell & 'C:\Users\J
COMPUTER\.cache\codex-runtimes\codex-primary-runtime\dependencies\python\python.exe'
'C:\Users\J
COMPUTER\.codex\skills\.system\skill-installer\scripts\install-skill-from-github.py'
--repo addyosmani/web-quality-skills --path skills/web-quality-audit --ref
7b59d48aaf1f793935002f4998dfccc656f40839 --dest 'E:\ohada saas\Focused
projects\stoquify\.codex\skills' ``
```

Preflight. Inventory the exact directory, frontmatter, references, scripts, links, commands, network expectations, and write behavior. Record MIT notice and SHA-256 file manifest. If the skill includes executable helpers, either exclude them through an approved content-only packaging step or block installation; do not silently install executable content as “just a checklist.”

Validation before use. Run the current Codex validator. Perform one report-only pilot on a bounded, non-sensitive public or synthetic UI journey. Compare findings with existing Playwright, accessibility, Lighthouse/browser, localization, and design-system evidence. Qualified reviewers own accessibility and security conclusions.

Rollback. Remove only `.codex\skills\web-quality-audit`, reload Codex, verify disappearance, and confirm no reports, hooks, caches, or root documents remain. Test removal before promotion.

Approval owners. Frontend/platform, accessibility, security, agent governance, legal/procurement.

5.3 Impeccable — 83.0

Preserved verdict: Adopt the deterministic design-audit capability through a controlled read-only pilot.

Stoquify value. The additive signal is its deterministic source-level detector, not another design authority. It can identify frontend anti-patterns and complement existing visual, accessibility, workflow, localization, and design-system gates.

Source and pins. `pbakaus/impeccable`, source commit `ae5e95101a6979e7f7973a4ff57680b3c7adc1ec`; observed Skill release `4.0.4` and CLI release `3.5.0`; Apache-2.0 plus `NOTICE.md`. The current README requires Node 22.18+, offers `npx impeccable install`, and states that `install/update` can write provider skill folders, `.codex/hooks.json`, `.impeccable` state, `PRODUCT.md`, and `DESIGN.md`. Codex hooks invoke

`.agents/skills/impeccable/scripts/hook.mjs` and require trust approval.

Decision. Do not use `npx impeccable install, update, init, document, link`, or plugin installation in the first pilot. Do not install hooks or write root design documents. The first candidate unit is the exact CLI detector in a disposable, non-global directory, operating on approved synthetic or copied non-sensitive UI fixtures with `--no-config` and report-only output.

Proposed Phase B command family — blocked until the `npm tarball URL`, `integrity digest`, `transitive dependency inventory`, and `post-install behavior` for exactly `impeccable@3.5.0` are recorded:

```
`powershell npm pack impeccable@3.5.0 --ignore-scripts npm install --prefix 'E:\ohada
saas\Focused projects\stoquify\.codex\vendor-pilots\impeccable-3.5.0' --ignore-scripts
--no-audit --no-fund impeccable@3.5.0 & 'E:\ohada saas\Focused projects\stoquify\.code
x\vendor-pilots\impeccable-3.5.0\node_modules\.bin\impeccable.cmd' detect --no-config
'E:\ohada saas\Focused projects\stoquify\.codex\vendor-pilots\fixtures\impeccable' ``
```

These commands are proposals, not authorization. `npm pack` and package execution remain prohibited until the exact Phase B pilot is approved.

Preflight. Verify Node compatibility; inspect package scripts, lock/integrity metadata, transitive dependencies, CLI entrypoint, network behavior, and all writes. Deny hooks, live mode, Puppeteer URL scans, root documents, `.gitignore` edits, autonomous code changes, and external model calls.

Validation. Validate any installed Codex skill payload with the current validator; the detector-only CLI itself requires version output, checksum verification, a synthetic seeded-defect benchmark, process/network observation, output-path verification, and comparison with existing Stoquify signals.

Rollback. Delete only the verified disposable pilot directory and outputs; verify no `.agents/skills/impeccable`, `.codex/hooks.json` entry, `.impeccable`, `PRODUCT.md`, or `DESIGN.md` was created. Removal must be rehearsed before any promotion.

Approval owners. Design system, frontend/platform, security, agent governance, legal/procurement.

5.4 Alibaba Open Code Review — 82.5

Preserved verdict: Controlled synthetic-code pilot; source/context transmission and artifact provenance block direct adoption.

Stoquify value. Deterministic diff partitioning, path-specific rules, line positioning, resumable sessions, and a repeatable seeded benchmark may improve code-review consistency. It does not replace native Codex review, ESLint, TypeScript, tests, service-boundary gates, secrets checks, migration checks, or human review.

Source and pin. `alibaba/open-code-review`, release tag `v1.8.8` (observed release commit `6dc3eb0`), path `skills/open-code-review`; Apache-2.0. The skill requires the separate `ocr` CLI. The `npm` package has used a `postinstall` binary downloader, so the `npm` package field is not sufficient provenance. A Phase B must use a release asset pinned to `v1.8.8`, verify the vendor checksum and locally computed SHA-256, and avoid global installation.

Data-flow controls. Default review reads Git diffs, may retrieve full files and repository context, and sends content to a configured LLM. Bare workspace mode includes staged, unstaged, and untracked files. Therefore:

- 1 only a separately created synthetic repository with seeded generic defects is in scope;
- 1 proprietary Stoquify source, diffs, filenames, rules, prompts, and data are prohibited from provider egress;
- 1 provider URL, model, subprocesses, DPA, data residency, retention, training/use terms, log content, and deletion must be approved;
- 1 delegation mode or an approved local model boundary is preferred; absence of an API key does not itself prove absence of egress;
- 1 telemetry stays disabled, content logging stays disabled, session output is disposable, concurrency is bounded, and auto-fix is disabled;

- 1 no MCP, CI, PR comments, repository writes, or production use.

Proposed Phase B skill command — documented, not executed:

```
`powershell & 'C:\Users\J
COMPUTER\.cache\codex-runtimes\codex-primary-runtime\dependencies\python\python.exe'
'C:\Users\J
COMPUTER\.codex\skills\.system\skill-installer\scripts\install-skill-from-github.py'
--repo alibaba/open-code-review --path skills/open-code-review --ref v1.8.8 --dest
'E:\ohada saas\Focused projects\stoquify\.codex\skills' ``
```

The skill must not be used until an exact Windows v1.8.8 binary asset, checksum, SBOM/dependency review, and disposable path are approved. No `npm install -g`, `npm post-install` downloader, latest URL, install script, or unpinned main is allowed.

Validation. Validate the installed skill with the current Codex validator. Verify CLI version/digest offline, then run `preview` or equivalent on the synthetic fixture before any model call. Benchmark seeded-defect precision/recall, false positives, file selection, line positioning, output writes, provider calls, telemetry, and removal.

Rollback. Remove the exact project-local skill, disposable binary, config, session store, and synthetic outputs; revoke/delete any pilot token at the provider; verify no hooks, MCP, CI, or source artifacts remain. Test this removal before promotion.

Approval owners. AppSec, privacy, legal/procurement, platform, quality engineering, agent governance.

5.5 Sentry sentry-nextjs-sdk — 78.5

Preserved verdict: Controlled, privacy-hardened staging pilot only; do not install or configure upstream examples unchanged.

Current-state finding. The scored repository `getsentry/sentry-agent-skills` is archived and directs new users to `getsentry/sentry-for-ai`. The current source freezes the per-SDK wizard skills under `skills-legacy` and uses a broader `sentry-instrument` skill. Its generated Codex distribution, `getsentry/plugin-codex`, contains the whole skill library and a `.mcp.json` that points to `https://mcp.sentry.dev/mcp?utm_source=plugin`. Installing that plugin would activate an external-service surface and conflicts with the Phase A/telemetry prohibition.

Reference pin. Current source reference reviewed at `getsentry/sentry-for-ai` commit `d33bb6d87734316d7561be0f9b78bec795ecd795`; MIT. This is a source reference, not an approved install pin. The generated Codex distribution has no approved stable release/checksum in this plan.

Decision. No Sentry skill, plugin, MCP, CLI, SDK, wizard, DSN, token, account, project, source-map upload, Seer/AI feature, replay, alert, or telemetry activation is approved. There is no safe Phase B install command yet.

Mandatory privacy contract before any future proposal:

- 1 `sendDefaultPii`: false in browser, server, and edge runtimes;
- 1 `includeLocalVariables`: false; no captured locals, request bodies, headers, cookies, auth tokens, URLs/query strings, tenant identifiers, employee data, financial data, provider payloads, or audit evidence;
- 1 session replay disabled; no replay on finance, payroll, identity, billing, provider, evidence, administrative, or customer-sensitive routes;
- 1 deny-by-default before `send` and equivalent scrubbing with adversarial synthetic tests;
- 1 staging-only non-sensitive route/job, synthetic identities, least-privilege roles and CI token, explicit data inventory, processor/subprocessor review, DPA, retention/deletion SLA, incident owner, and access review;
- 1 approved region/residency decision; Sentry documents region-specific US and DE API domains, but organization configuration and contractual storage/processing scope must be verified independently;
- 1 source maps, releases, logs, traces, profiles, AI inputs/outputs, user feedback, attachments, and IP/user-agent handling each require an explicit allow/deny decision;

- 1 no MCP, Seer auto-fix, GitHub repository connection, autonomous writes, or production approval in the pilot.

Future validation and rollback. If a later execution prompt approves application changes, pin the exact `@sentry/nextjs` package and lockfile integrity, inspect lifecycle scripts and transitive dependencies, use a reviewable code diff, then run only the requested focused application checks. Test removal by eliminating SDK initialization/configuration, dependency and lockfile entries, DSN/token wiring, source-map upload, build integration, and service project; verify no events are received after removal and request deletion of pilot data.

Approval owners. Privacy/DPO, security, legal/procurement, platform/SRE, application owner, incident owner, agent governance.

5.6 Trail of Bits supply-chain-risk-auditor — 74.5

Preserved verdict: Controlled advisory pilot.

Stoquify value. It adds maintainer concentration, abandonment, popularity, dangerous capability, security-contact, and takeover-risk heuristics that ordinary CVE scanners can miss.

Source and pin. `trailofbits/skills`, path `plugins/supply-chain-risk-auditor/skills/supply-chain-risk-auditor`, commit `cfe5d7b1619e47fb5b38b7e2561dad7e5f1e89af`; **CC-BY-SA-4.0**, not Apache or MIT. Attribution and ShareAlike obligations require legal review before adaptation or distribution.

Limitations. The upstream skill explicitly says it is not active vulnerability scanning, runtime dependency analysis, or license compliance auditing. It declares `Read`, `Write`, `Bash`, `Glob`, and `Grep`, requires `gh`, queries live GitHub data, and writes `.supply-chain-risk-auditor/results.md`. Those defaults are incompatible with a silent read-only install and would create a parallel evidence location.

Decision. Do not install upstream unchanged. Adapt the criteria into a Stoquify-owned, Windows-compatible, read-only advisory workflow that writes only to an approved existing release-evidence location, records timestamps and sources, and remains subordinate to SCA, SBOM, signature/provenance, license, secrets, container, CVE, and human release gates.

Reference-only installer command — documented but blocked from execution:

```
``powershell & 'C:\Users\J
COMPUTER\.cache\codex-runtimes\codex-primary-runtime\dependencies\python\python.exe'
'C:\Users\J
COMPUTER\.codex\skills\.system\skill-installer\scripts\install-skill-from-github.py'
--repo trailofbits/skills --path
plugins/supply-chain-risk-auditor/skills/supply-chain-risk-auditor --ref
cfe5d7b1619e47fb5b38b7e2561dad7e5f1e89af --dest 'E:\ohada saas\Focused
projects\stoquify\.codex\vendor-pilots\quarantine' ``
```

Preflight and validation. Legal approves CC-BY-SA obligations; AppSec defines network/query limits and evidence schema; GitHub identity/scopes are reviewed without reading credentials; all commands/writes are translated and allowlisted. Validate any adapted Codex skill with the current validator, compare its advisory output with deterministic scanners, and measure unsupported/false claims.

Rollback. Remove only the quarantined or adapted skill and its approved report outputs; revoke pilot GitHub permissions if any were granted; verify no `.supply-chain-risk-auditor` directory or release-gate configuration remains. Test removal before promotion.

Approval owners. AppSec/supply-chain owner, legal/procurement, platform, release engineering, agent governance.

5.7 Anthropic Skill Creator — 70.5

Preserved verdict: Selectively adapt methods; no whole-skill install.

Stoquify value. Portable ideas include with-skill/baseline comparisons, discriminating assertions, blind review, human example review, token/time capture, benchmark aggregation, trigger-description testing, and variance

analysis.

Source and pin. anthropics/skills, path skills/skill-creator, commit 690f15cac7f7b4c055c5ab109c79ed9259934081; skill-specific Apache-2.0 license. Upstream is a Claude-oriented workflow with Claude helpers and POSIX/Bash assumptions.

Conflict. Codex already provides C:\Users\J COMPUTER\.codex\skills\.system\skill-creator. Installing another skill named skill-creator would duplicate or shadow the system authority and create a competing lifecycle.

Decision. No installation command is proposed. Record Apache notice obligations and adapt only the useful evaluation patterns into the existing Stoquify/Codex lifecycle through an ordinary reviewed documentation or test change. Do not introduce Claude API/runtime helpers, background processes, separate evaluation truth, or claims that a passing benchmark certifies safety or correctness.

Validation and rollback. Any future internal adaptation must be named for its Stoquify purpose, validated with the current Codex validator if it is a skill, reviewed for overlap, and tested on synthetic examples. Rollback is the ordinary reviewable removal of that internal delta; the Codex system skill-creator must remain untouched.

Approval owners. Agent governance, quality engineering, security, legal/procurement.

6. Cross-candidate dependency, network, credential, and write register

Supabase	None for guidance review	None required for the skill itself	Installer writes one project-local directory; updates are explicit repins only
Addy	None for checklist; deterministic evidence tools are separate	No credential required for guidance; browser/network measurements separately approved	Possible executable helpers must be allowlisted; no automatic update
Impeccable	Node >=22.18; npm package/transitives; optional browser tooling	Detector on local files should need no credential; URL/live modes may use network	Installer/update can add skill folders, hooks, .impeccable, PRODUCT.md, DESIGN.md; all denied in first pilot
Alibaba	Git >=2.41; ocr binary; skill; configured model/provider in default mode	Model endpoint/token and possible telemetry; source/context egress	Config/session/output files; npm post-install downloader; CI/MCP/hooks possible; all separately governed
Sentry	Current Codex plugin, hosted MCP, and optional runtime SDK/service	MCP/Sentry accounts, DSN, tokens, telemetry and source-map upload	Plugin configures MCP; SDK writes app config and transmits events; blocked
Trail of Bits	gh, shell/query workflow	Live GitHub queries and possibly authenticated scopes	Writes its own results directory by default; direct install blocked
Anthropic	Claude-specific helpers/POSIX workflow upstream	Potential Claude runtime/API use upstream	Evaluation artifacts/process helpers; only patterns may be adapted internally

7. Phase B validation contract

For each approved Codex skill, run the current validator before use:

```
`powershell & 'C:\Users\J
COMPUTER\.cache\codex-runtimes\codex-primary-runtime\dependencies\python\python.exe'
'C:\Users\J COMPUTER\.codex\skills\.system\skill-creator\scripts\quick_validate.py'
'E:\ohada saas\Focused projects\stoquify\.codex\skills\<approved-skill-directory>' ``

<approved-skill-directory> must be replaced only in the candidate-specific execution prompt. Validation does
not authorize invocation.
```

If, and only if, an approved Phase B changes application code or dependencies, run the focused checks authorized by the prompt:

```
`powershell npm run typecheck npm run lint npm run policy:gates npm run prisma:validate
npm run test:e2e -- --project=<approved-focused-project>`
```

Do not run the full build or full test suite unless the approved integration scope specifically requires it.

8. Promotion and removal gates

No candidate can be promoted until all applicable gates pass:

- 1 Exact commit or release, repository path, license, notices, file inventory, SHA-256 manifest, dependencies, lifecycle scripts, network calls, credentials, writes, hooks, and update owner are recorded.
- 2 The project-local or disposable install succeeds without touching unrelated files.
- 3 Every installed Codex skill passes the current Codex validator before use.
- 4 Synthetic or non-sensitive benchmark evidence meets candidate-specific criteria and is human-reviewed.
- 5 No skill claims certification of security, privacy, accessibility, accounting, statutory compliance, or release readiness.
- 6 The exact removal procedure is executed in the pilot, and post-removal checks prove no skill, hook, MCP, service, config, cache, dependency, credential, or output residue remains.
- 7 Updates are manual, reviewable repins owned by Agent Governance with relevant domain owners; no `latest`, unpinned `main`, auto-update, or silent upstream drift.

9. Human approval gate

PHASE A ENDS HERE.

Nothing in this plan authorizes Phase B. Human approval must select a named candidate, exact pin, allowed unit, data class, destination, network policy, write policy, success threshold, rollback test, and owners. The safest next approval is a combined but independently reversible execution prompt for only:

- 1 Supabase `supabase-postgres-best-practices` at commit `1ad9aaeb49caafd9e95c0a91116f71890eebbc53`; and
- 1 Addy web-quality-audit at commit `7b59d48aaf1f793935002f4998dfccc656f40839`, conditional on content/script allowlisting.

All other candidates require separate execution prompts and approvals. Sentry remains disabled.

10. Primary source register

- 1 Supabase: [repository](#), [pinned skill directory](#), [license](#)
- 1 Addy Osmani: [repository](#), [skill](#), [license](#)
- 1 Impeccable: [repository and install/write behavior](#), [releases](#), [package manifest](#), [license](#)
- 1 Alibaba: [repository and data flow](#), [skill](#), [v1.8.8 release](#), [license](#)
- 1 Sentry: [archived scored repository](#), [current source repository](#), [Codex distribution](#), [Codex plugin MCP configuration](#), [Next.js SDK docs](#), [regional API domains](#)
- 1 Trail of Bits: [repository](#), [pinned skill](#), [CC-BY-SA-4.0 license](#)
- 1 Anthropic: [repository](#), [Skill Creator](#), [skill license](#)

11. Verification record

- 1 Candidate count: **7**
- 1 Scores below 70 included: **0**
- 1 Candidate installation/download/execution/activation during Phase A: **0**
- 1 Application code or dependency changes: **0**
- 1 Application checks run: **0**, correctly omitted because no approved Phase B application change occurred
- 1 Artifacts required: Markdown, PDF, JSON
- 1 JSON schema/content validation and PDF page/text validation: recorded in the final handoff after rendering